

MERIDIAN FINANCIAL SERVICES · REAL-TIME FRAUD DETECTION SYSTEM

Meridian Sentinel — System Architecture

How the system detects bank fraud in real time using a combination of hand-written rules and an AI model trained on 6.3 million transactions.

Stack: Python · PyTorch · Elastic Stack · React · Docker · GitHub Actions

KM

Kevin Mugambi
Security Engineer

Dataset: PaySim · 6.3 Million Transactions · Split: 70% Train / 15% Validation / 15% Test

What does this system do? Every time a customer at Meridian Financial makes a payment — via phone, web, ATM, or wire — the system checks whether it looks like fraud. It does this in under 2 seconds, automatically, without the customer noticing. If something looks suspicious, the account is frozen immediately and a security analyst is alerted. If everything looks fine, the payment goes through as normal. The architecture below shows exactly how that happens, step by step.

01 DATA SOURCES — Where does the data come from?

Mobile Banking
Every time a customer taps to pay or transfers money on their phone, a log entry is created and sent to the system instantly.

Online Banking
Web-based logins, transfers, and bill payments generate event logs that are streamed into the pipeline in the same way.

ATM Network
Cash withdrawals include physical location data. This is used later to catch impossible travel — e.g. a card used in two cities within minutes.

Wire Transfers
High-value inter-bank payments (SWIFT / ACH). The highest fraud risk channel. Any single transfer above \$10,000 is automatically examined.

All four channels stream logs simultaneously · Encrypted with TLS 1.3 (same as HTTPS banking)

02 INGESTION AND NORMALISATION — Cleaning and standardising the incoming data

Elastic Beats + Logstash — The Data Cleaning Room
Think of this as the system's front door. All four data channels arrive here at the same time. Three things happen before anything else touches the data:

- **Privacy protection first:** Customer names and card numbers are scrambled using SHA-256 (a one-way mathematical process — once scrambled, the original cannot be recovered). This satisfies the Australian Privacy Act 1988 and means no other part of the system ever sees real customer names.
- **One common format:** A mobile banking log looks very different from an ATM log. Logstash maps all of them into one standard layout called the Elastic Common Schema (ECS) so every part of the system downstream only needs to understand one format.
- **Parallel processing:** All four channels are processed simultaneously — no channel waits for another. This is how the system keeps its under-2-second response time.

Clean, standardised, anonymised data fans out to two places at once →

03 FEATURE ENGINEERING AND SEQUENCE CACHE — Building a picture of "normal" for each customer

Feature Engineering Service
Raw transaction data cannot be fed directly into the AI model — it needs to be turned into a structured "fingerprint" first. This service does that translation.

- **Sliding window of 5 transactions:** For every new event, the service fetches that customer's 5 most recent transactions and treats them as a sequence — a short story of recent behaviour.

Sequence KV-Cache (Redis)
This is a fast in-memory notebook that holds each customer's last 5 transactions. It prevents the system from having to ask the main database on every single event — which would be too slow.

- **Structure:** One entry per customer. Each entry holds 5 time slots: [t-4, t-3, t-2, t-1, t]. The oldest slot is always the one about to be replaced.

→ 12 signals extracted per transaction: Amount change, balance used up (%), channel type, time of day, speed between locations, merchant category, how often they transacted in the past hour and past 24 hours, total spend ratio, how risky the recipient is, how unusual the amount is compared to their average (z-score), and session unpredictability (entropy). → Output: A 5 × 12 grid of numbers — the exact format the AI model expects. Consistent every single time.	→ On a new transaction: The oldest slot (t-4) is dropped. The new transaction slides into the t slot. The window moves forward automatically. → New customers: If a customer has fewer than 5 transactions in history, the empty slots are filled with zeroes. The AI model receives a full grid regardless. → Why Redis? Redis reads from memory, not disk. It responds in under a millisecond — 100× faster than a regular database. This speed is critical to meet the 2-second target.
--	--



04a **DETECTION ENGINE** — Two completely different detectors run in parallel on every transaction

SIEM Rule Engine — The Checklist Detector This is a set of four hard-coded rules written by the security team. Think of it as a checklist an experienced fraud analyst would apply instantly. It is fast, predictable, and fully explainable. → Rule 1 — Large amount: Any single transaction over \$10,000 is flagged as HIGH risk. No exceptions. → Rule 2 — Impossible travel: If a card was used in one city and then appears in another city at a speed of more than 500 km/h, that is physically impossible and flagged as HIGH risk. → Rule 3 — Unusual hours: A transaction outside 08:00–22:00 AEST is flagged as MEDIUM risk — unusual hours are a known fraud pattern. → Rule 4 — Flagged merchant: If the merchant appears on the security team's watchlist, the transaction is flagged as HIGH risk immediately. → Produces a score: 0 rules fired = 0.0 · 1 rule = 0.33 · 2 rules = 0.67 · 3 or more = 1.0. This number feeds into the final verdict.	LSTM Anomaly Engine — The AI Brain This is a neural network — a type of AI — that has been trained on 6.3 million historical transactions to understand what "normal" looks like for each individual customer. Rules catch known fraud patterns. The AI catches unknown ones. → What is an LSTM? Long Short-Term Memory — a type of AI designed specifically for sequences (like a customer's history of purchases). It remembers patterns over time, not just individual events. → Architecture: Two stacked layers — Layer 1 has 128 units and learns short-term patterns in the last few transactions. Layer 2 has 64 units and learns longer behavioural context (e.g. "this customer never shops at electronics stores"). → Dropout (30%): During training, 30% of connections are randomly switched off each round. This forces the model to learn general patterns rather than memorising the training data — a technique called regularisation. → Output: A suspicion score between 0.0 (completely normal) and 1.0 (extremely unusual). Served via a REST API endpoint — any part of the system can query it. → Performance targets: Accuracy ≥ 98.55% · False Positive Rate ≤ 0.50% · Response time under 200 milliseconds.
--	--



04b **HYBRID THREAT SCORING** — The decision gate: combining both signals into one verdict

HybridThreatScorer — Where the Two Detectors Meet Neither detector alone is enough. Rules miss novel fraud patterns the security team hasn't anticipated yet. The AI has false positives — sometimes flags legitimate transactions. Together, weighted and combined, they are significantly more accurate than either alone. HOW THE FINAL THREAT SCORE IS CALCULATED threat_score = (AI suspicion score × 0.6) + (rule score × 0.4) The AI score gets 60% of the weight because it catches patterns rules cannot anticipate. The rule score gets 40% because it provides speed and explainability — if a rule fires, the analyst immediately knows exactly why. The threshold: If the combined score is 0.70 or above → the transaction is HIGH RISK and automatic containment fires. Below 0.70 → the transaction is SAFE and completes normally. Real example from testing (Customer CUST-18656, Darwin NT): Made 6 purchases at electronics and restaurant merchants. None of the 4 rules fired (rule score = 0.0). But the AI noticed the
--

spending pattern was very unusual for this customer and returned a suspicion score of 0.74. Combined: $(0.74 \times 0.6) + (0.0 \times 0.4) = 0.74$. Result: FLAGGED. This is exactly why having the AI alongside the rules matters — the rules alone would have cleared this transaction.

SUSPICIOUS — score ≥ 0.70

SAFE — score < 0.70

05 RESPONSE AND COMPLIANCE — *What happens immediately after the verdict*

SUSPICIOUS PATH — SCORE ≥ 0.70

Playbook Engine — Automatic Containment

The moment a transaction is flagged, this component fires automatically — before a human even sees the alert. No delay, no waiting for an analyst to wake up.

- **Account freeze:** An API call locks the customer's account instantly. The customer cannot make further transactions until a human analyst reviews the case.
- **Incident record created:** A structured case file is written to the database — containing the transaction details, which rules fired, the AI score, and the timestamp. The analyst has everything they need in one place.
- **Analyst notification:** An alert is dispatched immediately (email or Teams message) to the security operations queue, ranked by severity.

SOC Dashboard — The Analyst's Screen

This is the web interface the security analyst uses. It shows all active alerts in real time, ranked by how serious they are, with a countdown timer showing how long is left in the SLA (Service Level Agreement — the agreed time to respond).

- **Live updates:** The screen polls the database every 5 seconds — new alerts appear automatically without the analyst needing to refresh the page.
- **Confirm or dismiss:** The analyst can click "Confirm Threat" (keeps the account frozen, escalates) or "Investigate" (opens a detailed view). Every click is recorded in the audit log with the analyst's identity and timestamp.
- **Accessible design:** Built to WCAG 2.2 Level AA — usable with a keyboard only, compatible with screen readers, readable under stress at any hour.

Compliance and Regulatory Reporting

Every fraud event automatically generates a signed audit record. This is required by Australian law and international payment standards — the system cannot be switched off without breaking compliance.

- **PCI DSS v4.0:** The international card payment security standard. Every control is mapped to a specific part of the system in the compliance document.
- **APRA CPS 234:** The Australian Prudential Regulation Authority's cybersecurity standard for financial institutions. Mandatory for all Australian banks.
- **Privacy Act 1988:** The SHA-256 hashing applied at Stage 2 directly satisfies the Australian Privacy Principles (APPs) for data handling.
- **Role-based access:** Six user roles exist. A security analyst can see alerts but cannot edit detection rules. A compliance officer can read audit logs but cannot touch the AI model.

SAFE PATH — SCORE < 0.70

Transaction Approved — Fully Automated

No fraud detected. The customer's payment goes through as normal. They experience no delay and receive no notification that anything happened. Entirely automated — zero analyst time consumed.

- The payment completes. The customer's action (transfer, purchase, withdrawal) processes as expected.
- **Memory updated:** This transaction becomes the new most-recent event (slot "t") in the customer's Redis cache. The oldest event is dropped. The next transaction for this customer will now be evaluated using this updated history.
- The event is recorded to both storage tiers (see Stage 6) for audit purposes and for future AI retraining.

(RBAC): Access is strictly separated.

Every event – suspicious or safe – is written to storage · Encrypted with AES-256

06 DATA STORAGE — Two tiers: fast access for now, permanent storage for later

Hot Store — Elasticsearch Cluster

- Fast, SSD-backed storage for everything the live system needs to query right now. Analysts, dashboards, and real-time alerts all read from here.
- Stores all incoming transaction logs and any alerts generated by the detection engine.
 - Also stores the analyst's actions — every "Confirm" and "Dismiss" click goes here as an audit trail.
 - **90-day rolling window:** After 90 days, data is automatically moved out. This keeps the cluster fast. Older data is not deleted — it moves to the Cold Store below.
 - Encrypted with AES-256 at rest. All connections use TLS 1.3.

Cold Store — S3-Compatible Object Vault

- Cheap, permanent storage for things that must be kept but are not needed every day. Think of it as the system's long-term filing cabinet.
- **AI model files:** The trained neural network is saved here in versioned snapshots. If a new version of the model performs worse, the team can roll back to a previous version instantly.
 - **Training data:** All 6.3 million PaySim records — stored as compressed arrays. Used to retrain the AI model as new fraud patterns emerge. Without this, the model would become outdated over time.
 - **Regulatory evidence:** All incident records are saved here permanently with cryptographic signatures — meaning they cannot be altered after the fact. Required by PCI DSS and APRA CPS 234 for regulatory audits.

INF INFRASTRUCTURE AND QUALITY ASSURANCE — The foundation that makes everything above run reliably

Docker — Containerised Deployment

- Every component of the system runs inside a Docker container — a self-contained package with all its own dependencies. This means the system runs identically on any machine, anywhere.
- One command starts the entire system: Elasticsearch, Kibana, Logstash, the AI inference server, and the feature engineering service — all launch together.
 - The AI model is served as its own container with a REST API. Any other component can ask it for a suspicion score by sending a simple web request.

GitHub CI/CD — Automated Quality Gate

- Every time a developer submits a code change, the system automatically runs checks before that code can be merged. Broken or incorrectly typed code is caught before it reaches the live system.
- **Two automatic checks:** Syntax checking (flake8 — catches typos and formatting errors) and type checking (mypy — catches logical errors where the wrong type of data is passed between components).
 - **Branch protection:** Code flows from the development branch to the production branch only after passing all checks and receiving a peer review. No one can push directly to production.

Acceptance Tests — 10 Proof Points

- Before the system is considered complete, it must pass 10 automated tests that prove each critical function works end to end. These are the acceptance criteria — the proof of delivery.
- AT-1: A log reaches Elasticsearch in under 2 seconds · AT-2: A known fraud pattern scores above 0.70 · AT-3: A clean transaction scores below 0.30
 - AT-4: A rule alert fires in under 1 second · AT-5: Account freeze is logged · AT-6: Analyst action appears in audit trail
 - AT-7: Compliance report exports correctly · AT-8: Dashboard fully usable by keyboard · AT-9: Analyst denied rule-editing access · AT-10: AI model retraining completes and promotes

12P 12 KEY DESIGN PRINCIPLES — The decisions that define how and why this system was built this way

1

Privacy by design

Customer identity is hashed at the very first step — before any analysis. No component downstream ever sees real names or card

2

Encrypt everything

Data is encrypted in transit (TLS 1.3) and at rest (AES-256). Interception of the data channel or access to the storage disk yields nothing readable.

3

Sub-2-second response

The entire pipeline — from transaction event to fraud verdict — must complete in under 2 seconds. Architecture choices like Redis

4

Rules plus AI together

Rules are explainable but rigid — they only catch what they were written for. AI is flexible but opaque. The hybrid approach takes the

numbers. This is not optional; it is an architectural constraint.		caching and parallel processing exist specifically to meet this constraint.	best of both and uses a weighted formula to combine them.
5 Per-customer AI models The LSTM does not compare a transaction against a global average — it compares it against that specific customer's own history. A large transaction is normal for one customer and fraud for another.	6 Auto-containment before review The account is frozen the instant the verdict fires — before any human reviews the case. Waiting for a human creates a window for further fraudulent transactions.	7 Tunable threshold The 70% decision threshold is a configuration value, not hard-coded. Raise it to reduce false alarms (fewer analyst interruptions). Lower it to catch more fraud (at the cost of more manual review). Adjustable without redeployment.	8 Strict role separation Six distinct user roles with no overlap. A security analyst cannot edit detection rules. A compliance officer cannot see live alerts. No single role has access to everything. This limits damage from insider threats or compromised accounts.
9 Tamper-evident audit trail Every incident record is cryptographically signed. If anyone attempts to alter a record after the fact, the signature breaks and the alteration is detectable. Required by PCI DSS v4.0 and APRA CPS 234.	10 Accessible analyst UI The SOC dashboard meets WCAG 2.2 Level AA — the international web accessibility standard. Fully keyboard-navigable, compatible with screen readers, sufficient colour contrast. Security analysts work irregular hours under stress; the interface must never add friction.	11 Hot and cold storage tiers Recent data lives in fast, expensive SSD storage for 90 days. Older data moves to cheap object storage permanently. This balances cost, speed, and the regulatory requirement to retain records indefinitely.	12 AI that keeps learning Fraud patterns evolve. The LSTM model is retrained periodically on new data stored in the Cold Store. New model versions are validated before replacing the live version. The system improves over time rather than becoming outdated.
KEY Section label System component Data flow <i>grey quote</i> Plain-English explanation → bullet Technical detail Accuracy target: ≥ 98.55% · False Positive Rate: ≤ 0.50% · End-to-end latency: < 2 sec			